

ERP/1: Авторизація

Техноробочий проєкт

на створення та впровадження модуля «Служба
ідентифікації та авторизації (IAS)» як засобу
інформатизації

Згідно з ДСТУ 34.201-89 та Постановою КМУ № 205 від 21.02.2025
Формалізація вимог за стандартом ISO/IEC/IEEE 29148:2018

Зміст

Зміст

1	Загальні відомості про засіб інформатизації	2
1.1	Найменування та підстави для розробки	2
1.2	Статуси опису реалізації	2
1.3	Простежуваність вимог та відповідність нормативній базі	2
1.4	Призначення та цілі створення засобу	3
1.5	Послідовність виконання наступних робіт	3
2	Відомості про робочий процес та умови експлуатації	5
2.1	Опис робочих процесів (BPMN / FSM)	5
2.1.1	Поточний процесний контур	5
2.1.2	Фактична модульна архітектура	5
2.2	Авторизація та атрибути доступу	6
2.3	Умови експлуатації та системне середовище	6
3	Інформаційне та програмне забезпечення	8
3.1	Інформаційне забезпечення (Схеми та Дані)	8
3.1.1	Визначення стійких структур даних	8
3.1.2	Опис довідників та реєстрових сутностей	9
3.1.3	Фактичний життєвий цикл майстра налаштування VPN	9
3.1.4	Передавання, звіряння та відновлення	10
3.2	Програмне забезпечення (Реалізація)	10
3.2.1	Цільова інтеграція з BPE	10
3.2.2	Модулі перевірки CSR і сертифікатів	10
3.3	Короткі алгоритми поточної реалізації	10
3.3.1	Перехід між кроками майстра	10
3.3.2	Передавання конфігурації до VPN	11
3.3.3	Звіряння та відновлення	11
4	Вимоги до засобу за ISO/IEC/IEEE 29148	12
4.1	Функціональні вимоги	12
4.2	Вимоги до інтерфейсів та оформлення	12
4.3	Вимоги до архітектури та надійності	12
4.4	Вимоги до випробувань	12
4.5	Вимоги до безпеки та захисту інформації	13
4.6	Вимоги до продуктивності та рівня обслуговування	13
4.7	Вимоги до журналювання та аудиту	13
4.8	Адміністративні, ліцензійні та експлуатаційні вимоги	13
5	Простежуваність реалізації та випробувань	14

1. Загальні відомості про засіб інформатизації

1.1. Найменування та підстави для розробки

Найменування засобу інформатизації: Модуль «Служба ідентифікації та авторизації (IAS)» (далі — Модуль IAS / Система IAS) у складі інформаційної системи управління підприємством ERP/1.

Підстави для розробки:

1. Закон України «Про захист інформації в інформаційно-телекомунікаційних системах».
2. Постанова Кабінету Міністрів України від 29.03.2006 № 373 «Про затвердження Правил забезпечення захисту інформації в інформаційних, телекомунікаційних та інформаційно-телекомунікаційних системах».
3. Постанова Кабінету Міністрів України від 21.02.2025 № 205 «Про затвердження Порядку використання засобів інформатизації».
4. Угода про асоціацію між Україною та Європейським Союзом (в частині транскордонної взаємодії електронних довірчих послуг).
5. Технічне завдання на побудову Zencrypted інфраструктури безпеки.

1.2. Статуси опису реалізації

Щоб не змішувати фактичну реалізацію, частково завершені можливості, цільову архітектуру та нормативні наміри, у цьому документі застосовуються такі статуси:

Статус	Зміст
Реалізовано	Підтверджено поточним кодом, стійкими структурами даних і автоматизованими тестами IAS.
Частково реалізовано	Реалізовано лише для визначеного сценарію або з тимчасовими технічними залежностями.
Цільовий стан	Запланована архітектура або функція наступних ітерацій; не трактується як наявна у поточному середовищі виконання.
Нормативна вимога	Вимога законодавства, стандарту, сертифікації або організаційної політики, що потребує окремих доказів реалізації та приймання.

1.3. Простежуваність вимог та відповідність нормативній базі

Техноробочий проєкт деталізує технічні вимоги з `ias.tex` і має зберігати зв'язок між вимогою, фактичним модулем, стійкою структурою даних, автоматизованим тестом та статусом реалізації. Посилання на неіснуючі модулі, демонстраційний код або майбутню архітектуру не повинні подаватися як опис поточного стану.

На цьому етапі зафіксовано такі межі простежуваності:

- Керування доменними об'єктами: користувачі, пристрої, сертифікати, профілі безпеки, політики та VPN-сервіси зберігаються у KVS/Mnesia через доменні модулі IAS. Статус: Реалізовано.
- Майстер налаштування VPN: поточний життєвий цикл виконується спеціалізованими модулями IAS з перевітками переходів, готовності матеріалів, доставки та відновлення. Статус: Реалізовано.
- Випуск сертифікатів через CA: поточний CMP-шлях використовує зовнішній командний інтерфейс OpenSSL і є перехідним. Повне усунення запуску OpenSSL із середовища виконання IAS є цільовим станом.
- Керування процесами через BPE/BPMN: майбутнє перенесення керування станами й переходами на `synrc/bpmn`/BPE є цільовим станом; поточний майстер поки не виконується рушієм BPE.
- EST, CMC, CRL/OCSP, повний ABAC, КСЗІ та національні криптографічні алгоритми: позначаються лише як цільові або нормативні вимоги до появи окремих реалізаційних і приймальних доказів.

1.4. Призначення та цілі створення засобу

Модуль IAS є центральною адміністративно-координаційною службою для керування цифровими ідентичностями, пристроями, сертифікатами, профілями безпеки, політиками та VPN-сервісами. IAS формує бажаний стан і передає керовані конфігурації до VPN, але не бере участі у пересиланні VPN-трафіку.

Поточні та цільові цілі:

- Реалізовано: стійкий реєстр доменних об'єктів у KVS/Mnesia, граф зв'язків, перевірка CSR і X.509, покрокове налаштування пристрою, передавання конфігурацій до VPN через Erlang RPC, ревізії, контрольні суми, журналювання доставки, звірення стану та відновлення після збоїв.
- Частково реалізовано: випуск сертифікатів через CA за CMP із зовнішнім командним інтерфейсом OpenSSL як перехідною залежністю.
- Цільовий стан: керований клієнт або адаптер CA без запуску зовнішнього OpenSSL у IAS, а також перенесення керування життєвим циклом майстра на `synrc/bpmn`/BPE зі збереженням наявних доменних модулів і перевіреної поведінки.
- Нормативна вимога: окреме підтвердження вимог КСЗІ, КЕП, криптографії за ДСТУ, захисту персональних даних та інших нормативних профілів.

1.5. Послідовність виконання наступних робіт

Календарні строки не фіксуються без окремої оцінки обсягу, ресурсів і критеріїв приймання. Роботи виконуються у такій залежній послідовності:

1. P0 — синхронізація документації: привести `ias.tex` і `ias_pro.tex` у відповідність до поточного коду та однакових статусів реалізації.
2. P1 — усунення OpenSSL із IAS: прибрати запуск зовнішнього командного інтерфейсу OpenSSL із середовища виконання IAS, зберігши CMP або інший погоджений контракт через керований клієнт чи адаптер CA.
3. P2 — стабілізація наскрізного сценарію: прогнати й стабілізувати повний життєвий цикл майстра налаштування VPN від користувача й пристрою до передавання конфігурації, повторних спроб і відновлення після збоїв.

4. P3 — опис поточного процесу: зафіксувати фактичну FSM/BPMN-модель станів, переходів, умов, помилок і завершення без розбіжностей із кодом.
5. P4 — перенесення керування на ВРЕ: поетапно зробити ВРЕ джерелом стану й переходів, залишивши майстер користувацьким інтерфейсом над процесом та зберігши доменні сервісні модулі.
6. P5 — повторна синхронізація: узгодити технічні вимоги, техноробочий проєкт, випробування та профілі безпеки після реалізації цільових змін.

2. Відомості про робочий процес та умови експлуатації

2.1. Опис робочих процесів (BPMN / FSM)

Поточні процеси IAS реалізовано спеціалізованими модулями та стійкими записами стану. Цей розділ фіксує фактичний процесний контур, а інтеграцію з BPE розглядає як цільовий етап розвитку.

2.1.1. Поточний процесний контур

У наявній реалізації окремі доменні сценарії координуються кодом IAS і збереженим станом:

- імпорт OVPN виконує попередній аналіз конфігурації та формує доменні об'єкти без збереження приватного ключа;
- випуск сертифіката приймає та перевіряє CSR, взаємодіє з CA і зв'язує результат із пристроєм та профілем безпеки;
- майстер налаштування VPN веде стійку чернетку, перевіряє умови переходів і готовність матеріалів;
- передавання конфігурації формує канонічну команду з ревізією та контрольною сумою, доставляє її до VPN і зберігає результат;
- звіряння стану виявляє розбіжності, осиротілі записи та потребу у відновленні або виведенні з експлуатації.

Фактичні стани, переходи, умови, повторні спроби та помилки мають бути окремо відтворені як модель поточного стану (AS IS) за кодом і тестами. Лише після цього керування процесом може бути поетапно перенесене на `synrc/bpmn/BPE`. У цільовій архітектурі BPE керує станами й переходами, а наявний майстер залишається користувацьким інтерфейсом над процесом.

2.1.2. Фактична модульна архітектура

Поточна реалізація поділена на веб-рівень, доменні служби, стійкі сховища та інтеграційні модулі. Веб-модулі не повинні містити криптографічну, транзакційну або мережеву логіку: вони приймають події користувача, викликають доменні служби та відображають результат.

Модуль або група модулів	Фактична відповідальність
<code>ias_provisioning_wizard.erl</code>	Веб-сторінка майстра: приймання подій, навігація між кроками та відображення стану. Не є авторитетним сховищем процесу.
<code>ias_provisioning_wizard_store.erl</code> , <code>ias_provisioning_wizard_draft_store.erl</code>	Створення, оновлення, відновлення та збереження чернетки майстра; вибір доменних об'єктів і виконання переходів між кроками.
<code>ias_provisioning_wizard_readiness.erl</code> , <code>ias_provisioning_wizard_relationships.erl</code> , <code>ias_provisioning_wizard_authorization.erl</code>	Перевірка готовності матеріалів, узгодженості графа зв'язків, сертифікатів і рішення про авторизацію перед передаванням конфігурації.

Модуль або група модулів	Фактична відповідальність
<code>ias_domain_store.erl</code>	Авторитетне стійке зберігання доменних об'єктів через KVS/Mnesia, перевірка схем і транзакційне оновлення проєкцій.
<code>ias_relationship_*</code>	Побудова, перевірка та відображення графа зв'язків між користувачами, пристроями, сертифікатами, профілями, політиками й VPN-сервісами.
<code>ias_csr_validation.erl</code> , <code>ias_certificate_verification.erl</code> , <code>ias_x509_validation.erl</code>	Перевірка CSR і X.509, зв'язування сертифікатного матеріалу з доменними об'єктами та формування результатів перевірки.
<code>ias_device_csr_enrollment.erl</code> , <code>ias_cmp_enrollment.erl</code>	Підготовка випуску сертифіката для пристрою та поточний перехідний СМР-шлях. <code>ias_cmp_enrollment.erl</code> поки запускає зовнішній OpenSSL і має бути замінений керованим клієнтом або адаптером СА.
<code>ias_ovpn_preview.erl</code> , <code>ias_ovpn_import.erl</code> , <code>ias_ovpn_provisioning.erl</code>	Аналіз OVPN, формування попереднього перегляду й доменної проєкції та підготовка керованого сценарію без збереження приватного ключа в IAS.
<code>ias_vpn_provisioning_command.erl</code> , <code>ias_vpn_provisioning_delivery.erl</code> , <code>ias_vpn_client.erl</code>	Формування канонічної команди, ревізії та контрольної суми, передавання до VPN через Erlang RPC і фіксація результату доставки.
<code>ias_vpn_reconciliation.erl</code> , <code>ias_vpn_orphan_recovery.erl</code> , <code>ias_vpn_recovery_manifest.erl</code>	Порівняння стану IAS і VPN, виявлення розбіжностей та осиротілих записів, планування й атомарне виконання відновлення.

Межі відповідальності є такими: KVS/Mnesia зберігає авторитетний стан IAS; СА випускає сертифікати; VPN застосовує передані команди та зберігає власний стан виконання; IAS координує процес, але не підміняє СА або VPN.

2.2. Авторизація та атрибути доступу

Поточна реалізація використовує профілі й політики безпеки, атрибути доменних об'єктів, граф зв'язків і стан довіри до сертифікатів для ухвалення рішень у сценаріях IAS/VPN. Фактичні перевірки виконуються доменними модулями політик, авторизаційних рішень, узгодженості політик і перевірки сертифікатів.

Такий механізм є частковою реалізацією атрибутної авторизації та не становить універсального рушія АВАС. Формалізована мова політик, адміністративні ролі, зовнішні джерела атрибутів, правила організаційної належності, класифікація ресурсів і загальний механізм оцінювання політик належать до цільового стану. Їхні моделі даних, набір атрибутів, правила переходу та критерії прийняття мають бути визначені окремо до реалізації.

2.3. Умови експлуатації та системне середовище

Система IAS повинна розгортатися у кластерному середовищі:

- Операційна система: Linux (Ubuntu Server LTS, Rocky Linux) або macOS (для розробки).
- Платформа: Erlang/OTP 28; підтримка інших основних версій потребує окремого випробування.

- Служби взаємодії: вузли розподіленого Erlang, виявлення через `erpm` та захист каналів відповідно до профілю розгортання.
- Вимоги до СУБД: Mnesia, інтегрована через інтерфейс KVS.

3. Інформаційне та програмне забезпечення

3.1. Інформаційне забезпечення (Схеми та Дані)

3.1.1. Визначення стійких структур даних

Нижче наведено лише фактичні записи, що існують у поточному репозиторії IAS. Канонічним джерелом складу полів залишаються відповідні файли у каталозі `include/`; цей документ фіксує їхнє призначення та роль у життєвому циклі.

Запис	Призначення
<code>ias_domain_object</code>	Універсальний версійований запис доменного об'єкта: вид, ідентифікатор, корисне навантаження, ревізія та часові мітки.
<code>ias_provisioning_wizard_draft</code>	Стійке представлення чернетки майстра: ідентифікатор, стан, корисне навантаження, ревізія та ознаки завершення або відмови.
<code>ias_certificate_material_record</code>	Публічний сертифікатний матеріал і метадані: суб'єкт, тип матеріалу, кодування, джерело, відбиток, конверт тіла та строк чинності.
<code>ias_csr_enrollment_record</code>	Стан спроби випуску за CSR: відбиток CSR, стан, ознака можливості повтору, корисне навантаження та ревізія.
<code>ias_vpn_device_state</code>	Авторитетний стан прив'язки пристрою до VPN: ревізія, контрольна сума команди, канонічна команда, мережеві параметри та стан життєвого циклу.
<code>ias_vpn_provisioning_delivery_audit</code>	Окрема спроба доставки: ідентифікатор доставки, пристрій, транзакція, номер спроби, операція, стан і час доставки.
<code>ias_vpn_reconciliation_incident</code>	Інцидент розбіжності між IAS і VPN: вид, причина, маркер, стан, знімок, лічильник повторів і дані підтвердження або завершення.
<code>ias_vpn_orphan_recovery_operation</code>	Керована операція відновлення осиротілого стану з планом, виконавцем, числом спроб, останньою помилкою та підсумком виконання.
<code>ias_vpn_orphan_resolution_operation</code>	Керована операція усунення осиротілого стану через VPN із запитом, результатом VPN, даними очищення та завершення інциденту.

Основні інваріанти зберігання:

- кожен стійкий запис має явну версію схеми;
- доменні зміни мають ревізію або інший однозначний маркер версії;
- приватні ключі не входять до жодної з наведених структур;
- журнали доставки та інциденти звіряння не підміняють авторитетний стан пристрою;
- операції відновлення й усунення мають власні стани, лічильники спроб і завершення, тому можуть безпечно продовжуватися після збою.

3.1.2. Опис довідників та реєстрових сутностей

Опис полів реєстрових сутностей (таких як **User**, **Device**, **Certificate**) відповідає таксономії, зазначеній у Технічних вимогах. Всі записи зберігаються у таблиці **Mnesia kvs**, яка містить записи типу **ias_domain_object** та інші допоміжні рекорди.

3.1.3. Фактичний життєвий цикл майстра налаштування VPN

Поточний майстер використовує десять кроків у фіксованому порядку:

1. схема;
2. користувач;
3. пристрій;
4. профіль і політика безпеки;
5. VPN-сервіс;
6. сертифікат CA;
7. клієнтський сертифікат;
8. зв'язки;
9. готовність матеріалів;
10. підготовка та передавання конфігурації.

Стан	Основна умова переходу	Дія та стійкий результат
Схема	Обрано підтримуваний сценарій	Створюється чернетка сценарію прив'язаного до пристрою налаштування.
Користувач	Вибрано наявного або створено нового користувача	У чернетці фіксується власник пристрою.
Пристрій	Пристрій належить обраному користувачеві	Фіксується пристрій і очищаються залежні результати попереднього налаштування.
Профіль і політика	Профіль сумісний зі сценарієм	Фіксується профіль, а політика виводиться з його доменного зв'язку.
VPN-сервіс	Сервіс доступний і сумісний із профілем	Фіксується ціль передавання конфігурації.
Сертифікат CA	Матеріал CA наявний і придатний для довіри	Фіксується якір довіри для VPN-сервісу.
Клієнтський сертифікат	Сертифікат узгоджений із CSR, пристроєм і профілем	Сертифікат вибирається або випускається; далі система намагається атомарно застосувати потрібні зв'язки.
Зв'язки	Відсутні конфлікти або їх можна виправити	Граф зв'язків застосовується; за успіху майстер автоматично переходить до перевірки готовності.
Готовність матеріалів	Успішні перевірки сертифікатів, довіри, авторизації та повноти	Фіксується готовність до створення транзакції; за потреби виконуються дії виправлення та повторна перевірка.
Підготовка і передавання	Сформовано канонічну команду, ревізію та контрольну суму	Створюється одна ідempotentна транзакція, команда передається до VPN, а спроби та результат зберігаються окремо.

Чернетка зберігається у стійкому сховищі й відновлюється до робочого представлення після

перезапуску. Перехід уперед заборонено, якщо для поточного кроку немає потрібних доменних об'єктів або перевірок. Після вибору клієнтського сертифіката майстер не завжди показує окремий екран зв'язків: якщо попередня перевірка успішна, відсутні зв'язки застосовуються автоматично і процес переходить одразу до готовності матеріалів.

3.1.4. Передавання, звіряння та відновлення

Після завершення майстра IAS формує канонічну команду з ревізією та контрольною сумою. Повторне передавання тієї самої команди є ідемпотентним, а застаріла ревізія не повинна перезаписувати новіший стан. Кожна спроба доставки має окремий запис аудиту.

Звіряння порівнює авторитетний стан IAS зі знімком VPN і створює інцидент для осиротілого запису, застарілої ревізії, невідповідності відбитка або іншого неузгодженого стану. Відновлення та усунення виконуються як окремі керовані операції з планом, числом спроб, останньою помилкою та явним завершенням. Це дозволяє повторити або продовжити операцію після перезапуску без повторного застосування старого бажаного стану.

3.2. Програмне забезпечення (Реалізація)

3.2.1. Цільова інтеграція з BPE

У поточній реалізації керування життєвим циклом виконується майстром і доменними сервісними модулями. Після фіксації моделі поточного стану (AS IS) може бути підготовлена цільова BPMN/BPE-модель. Вона повинна повторно використовувати наявні доменні модулі як сервісні дії, зберігати перевірену поведінку та не переносити криптографічну або доменну логіку безпосередньо до визначення процесу.

3.2.2. Модулі перевірки CSR і сертифікатів

Функції перевірки CSR, X.509, сертифікатів і довіри розподілено між такими модулями:

- `ias_csr_validation.erl` — синтаксична та структурна перевірка CSR;
- `ias_x509_validation.erl` — розбір і перевірка матеріалу X.509;
- `ias_certificate_verification.erl` — перевірка сертифіката у доменному контексті IAS;
- `ias_configured_ca_trust_anchor.erl` — отримання налаштованого якоря довіри СА;
- `ias_certificate_material_store.erl` — стійке зберігання публічного сертифікатного матеріалу та метаданих.

Приватні ключі пристроїв не передаються цим модулям і не зберігаються в IAS. Перевірка CRL/OCSP у режимі реального часу залишається цільовим станом до появи окремого реалізованого й протестованого адаптера.

3.3. Короткі алгоритми поточної реалізації

Наведені нижче алгоритми є стислим описом фактичної поведінки. Вони не замінюють код і не вводять нових назв модулів або неіснуючих інтерфейсів.

3.3.1. Перехід між кроками майстра

1. Завантажити стійку чернетку та визначити поточний крок.
2. Перевірити наявність і узгодженість матеріалів, потрібних для переходу.

3. У разі помилки зберегти результат перевірки та залишити поточний крок без змін.
4. У разі успіху зберегти вибрані доменні ідентифікатори, очистити залежні застарілі результати та перейти до наступного кроку.
5. Після зміни сертифіката або графа зв'язків повторно обчислити готовність матеріалів.

3.3.2. Передавання конфігурації до VPN

1. Побудувати канонічну команду з ревізією та контрольною сумою.
2. Знайти або створити одну ідемпотентну транзакцію для цієї команди.
3. Передати команду до VPN через Erlang RPC та окремо зафіксувати спробу доставки.
4. Зберегти отриманий від VPN результат або стан очікування повтору без втрати авторитетного стану IAS.
5. Після відновлення зв'язку повторити лише незавершені спроби та виконати звіряння стану.

3.3.3. Звіряння та відновлення

1. Отримати авторитетний стан IAS і знімок фактичного стану VPN.
2. Порівняти ревізії, контрольні суми, відбитки сертифікатів і стан життєвого циклу.
3. За відсутності розбіжностей закрити або підтвердити відповідний інцидент.
4. За наявності розбіжностей створити або оновити інцидент і сформулювати план відновлення чи виведення з експлуатації.
5. Виконувати план як окрему стійку операцію з лічильником спроб, останньою помилкою та явним завершенням.

4. Вимоги до засобу за ISO/IEC/IEEE 29148

4.1. Функціональні вимоги

Система повинна забезпечувати керування ідентичностями, пристроями, сертифікатами, профілями безпеки та VPN-сервісами; перевірку CSR і X.509; підготовку та передавання керованих VPN-конфігурацій; журналювання доставки; звіряння бажаного і фактичного станів; відновлення після збоїв та контроль виведення об'єктів з експлуатації. Конкретний статус кожної можливості визначається розділами цього техноробочого проєкту та технічними вимогами ERP/1.

4.2. Вимоги до інтерфейсів та оформлення

- Реалізовано: адміністративний веб-інтерфейс побудовано на N2O/NITRO/Cowboy і він працює поверх фактичних доменних модулів IAS.
- Цільовий стан: вимоги до доступності інтерфейсів, зокрема відповідність WCAG 2.1 рівню AA, визначаються окремими критеріями приймання та мають бути підтверджені спеціалізованим аудитом.
- Організаційна вимога: візуальне оформлення повинно відповідати погодженому фірмовому стилю Zencrypted; конкретна тема або режим відображення не вважаються властивістю поточної реалізації без окремого затвердження.

4.3. Вимоги до архітектури та надійності

- Реалізовано: IAS є застосунком Erlang/OTP із деревами нагляду та відновлюваними після перезапуску процесами.
- Реалізовано: авторитетний стан зберігається у KVS/Mnesia; стійкі записи мають явні версії схем і повинні оновлюватися керованими міграціями.
- Реалізовано: повторне передавання однакової канонічної команди до VPN є ідемпотентним, а застаріла ревізія не може перезаписати новіший стан.
- Реалізовано: стан доставки, інциденти звіряння та операції відновлення зберігаються так, щоб робота могла продовжуватися після перезапуску або тимчасової недоступності VPN.
- Поточна платформа: IAS орієнтований на Erlang/OTP 28 і використовує стандартний модуль `json` із `stdlib`; підтримка інших основних версій OTP не заявляється без окремого випробування.

4.4. Вимоги до випробувань

- Реалізовано: модульні перевірки виконуються наборами EUnit для доменних модулів, перевірок і перетворень даних.
- Реалізовано: інтеграційні та відновлювальні сценарії перевіряються наборами Common Test, зокрема для стійкості KVS/Mnesia, IAS → VPN RPC, ревізій, звіряння стану та відновлення після перезапуску.

- Кожна зміна формату стійких записів, канонічної команди або контракту IAS/VPN повинна супроводжуватися перевіркою міграції та повторного відтворення стану.
- Цільові показники доступності, часу відновлення, пропускної здатності та затримки визначаються лише за результатами окремих навантажувальних і приймальних випробувань.

4.5. Вимоги до безпеки та захисту інформації

- Реалізовано: приватні ключі користувачів і пристроїв не зберігаються та не передаються через IAS.
- Секрети, повний ключовий матеріал і значення облікових даних не повинні потрапляти до журналів аудиту або системних журналів.
- Захист транспортного рівня, автентифікація вузлів і порядок розподілу секретів повинні бути визначені для кожного профілю розгортання.
- Цільовий стан: застосування TLS 1.3 до конкретних зовнішніх каналів визначається архітектурою відповідного профілю і підтверджується інтеграційними випробуваннями; воно не поширюється автоматично на всі внутрішні канали системи.
- Нормативна вимога: КСЗІ ГЗ, КЕП CAdES-X Long, ДСТУ 4145-2002, ДСТУ ГОСТ 28147:2009 та шифрування даних у сховищі потребують окремих реалізаційних, випробувальних і атестаційних доказів.

4.6. Вимоги до продуктивності та рівня обслуговування

Значення доступності, RTO, RPO, пропускної здатності та затримки не фіксуються в цьому документі без вимірювань. До проведення навантажувальних і приймальних випробувань вони мають статус «Цільовий стан». Методика випробувань повинна визначати конфігурацію вузлів, обсяг KVS/Mnesia, кількість керованих об'єктів, характер VPN-навантаження, умови відмови та критерії успішного відновлення.

4.7. Вимоги до журналювання та аудиту

- Реалізовано: IAS реєструє в журналі аудиту переходи життєвого циклу, випуск та імпорт сертифікатів, рішення про авторизацію, передавання конфігурацій, інциденти звірення та дії відновлення.
- Запис аудиту повинен містити ідентифікатор об'єкта, ревізію або версію, результат, причину та часову мітку, якщо ці дані застосовні до події.
- Цільовий стан / вимога до розгортання: криптографічне підписання подій, незмінне WORM-сховище, передавання до ELK/Loki та строки довгострокового зберігання визначаються окремим профілем безпеки і не вважаються автоматично реалізованими властивостями IAS.

4.8. Адміністративні, ліцензійні та експлуатаційні вимоги

- Перелік ліцензій усіх залежностей формується за фактичним складом постачання; документ не обмежує допустимі ліцензії лише MIT або Apache 2.0 без окремого юридичного рішення.

- Потреба у сторонньому програмному забезпеченні, системних пакетах і зовнішніх сервісах повинна бути явно зазначена в описі розгортання. Цільовий стан IAS не передбачає запуск зовнішнього командного інтерфейсу OpenSSL у його середовищі виконання.
- Настанови адміністратора й оператора повинні відповідати фактичним інтерфейсам, режимам запуску, процедурам резервного копіювання, відновлення та діагностики.

5. Простежуваність реалізації та випробувань

Таблиця пов'язує основні вимоги з фактичними зонами коду й автоматизованими перевітками. Назви файлів наведено як орієнтири; канонічним доказом лишаються поточний код, результати EUnit/Common Test і приймальні матеріали конкретної версії.

ID	Вимога	Модулі та дані	Автоматизована перевірка
IAS-FR-001	Стійкий реєстр доменних об'єктів	<code>ias_domain_store.erl</code> , <code>ias_domain_object</code>	<code>ias_domain_store_tests.erl</code> , <code>ias_persistence_SUITE.erl</code>
IAS-FR-002	Перевірка CSR і X.509	<code>ias_csr_validation.erl</code> , <code>ias_x509_validation.erl</code> , <code>ias_certificate_verification.erl</code>	<code>ias_x509_validation_tests.erl</code> , <code>ias_certificate_verification_tests.erl</code>
IAS-FR-003	Випуск через CA без зовнішнього OpenSSL у IAS	Поточний перехідний шлях: <code>ias_device_csr_enrollment.erl</code> , <code>ias_cmp_enrollment.erl</code> ; ціль: керований клієнт або адаптер CA	Нааявні тести поточного шляху не є доказом завершення цільового стану
IAS-FR-004	Майстер налаштування VPN	<code>ias_provisioning_wizard_store.erl</code> , <code>ias_provisioning_wizard_draft</code> , модулі готовності, зв'язків і авторизації	<code>ias_provisioning_wizard_tests.erl</code> , <code>ias_provisioning_wizard_transaction_tests.erl</code>
IAS-FR-005	Передавання IAS → VPN	<code>ias_vpn_provisioning_command.erl</code> , <code>ias_vpn_provisioning_delivery.erl</code> , <code>ias_vpn_client.erl</code>	<code>ias_vpn_provisioning_delivery_tests.erl</code> , <code>ias_vpn_rpc_SUITE.erl</code>
IAS-FR-006	Ревізії, контрольні суми та ідемпотентність	<code>ias_vpn_device_state</code> , <code>ias_vpn_provisioning_delivery_audit</code> , модулі формування команди й доставки	<code>ias_vpn_provisioning_command_digest_tests.erl</code> , <code>ias_vpn_provisioning_delivery_store_tests.erl</code>

ID	Вимога	Модулі та дані	Автоматизована перевірка
IAS-FR-007	Звіряння, відновлення й усунення осиротілих станів	<code>ias_vpn_reconciliation.erl</code> , <code>ias_vpn_orphan_recovery.erl</code> , записи інцидентів та операцій	<code>ias_vpn_reconciliation_tests.erl</code> , <code>ias_vpn_recovery_manifest_tests.erl</code>
IAS-FR-008	Керування процесом через BPE/BPMN	Цільовий стан після фіксації моделі поточного стану; майстер лишається користувацьким інтерфейсом над процесом	Критерії та набори випробувань визначаються під час реалізації
IAS-FR-009	CRL/OCSP, EST і CMC	Цільові адаптери, відсутні в поточному середовищі виконання IAS	Потребують окремих інтеграційних і приймальних випробувань
IAS-NFR-001	КСЗІ, КЕП і криптографія за ДСТУ	Нормативні вимоги до профілів розгортання та окремих реалізацій	Потребують випробувальних і атестаційних доказів